Request for a technical evaluation

Independent runtime evidence for autonomous AI in regulated financial systems

To: Chief General Manager, FinTech Department, Reserve Bank of India | **Copy:** Aditi Dubey, FinTech Department

1. What we are asking for

A technical evaluation session of approximately 45 minutes with officers who can challenge the system on its evidence, and the Department's guidance on the appropriate pathway for that evaluation — the RBI Innovation Hub, the Regulatory Sandbox, or a directly supervised pilot with one regulated entity.

We are not asking for endorsement, funding, regulatory approval, or any statement the Bank could be quoted on. We are asking to be tested.

2. The problem, in one paragraph

When an AI agent executes a consequential action inside a regulated entity — moving funds, changing a limit, closing a case — the only account of what happened is usually the agent's own logs and its own explanation. If that account is wrong, whether through a defect or through compromise, nothing independent contradicts it. The entity cannot demonstrate to a supervisor what actually ran, and a customer disputing a transaction is answered by the system that performed it.

Sniffer Dog produces a second, independent account. An observer that is not the agent, and does not trust it, records execution from the Linux kernel. A decision point that is not the agent signs what was authorised *before* the act. The institution's own tool gateway countersigns what it actually received. A reconciler compares them and signs a verdict. Every record is verifiable offline by the entity's auditor, or by the Bank, using keys the institution holds. No step requires trusting VANIAN.

The governing design rule is that absence of evidence is never converted into an accusation. When the observer was not watching, or was interfered with, the system returns CANNOT_PROVE and says why. A monitoring product that manufactures confident findings from missing data is worse than none in a regulated setting, because it is switched off after the first false accusation.

3. Why we are bringing it to the FinTech Department

- The IT Governance directions require audit trails sufficient for forensics, dispute resolution and non-repudiation. An agent's self-report is none of those.
- The Outsourcing of IT Services directions hold that a regulated entity may outsource the activity but never the accountability. Independent evidence is what makes retained accountability demonstrable rather than contractual.
- The FREE-AI framework asks entities to maintain an inventory of AI systems and their behaviour. The system produces a signed per-agent ledger of every system an agent actually reached, named by the institution's own signed registry.
- CERT-In's six-hour incident reporting window is difficult to meet when the evidence must first be assembled. A signed incident bundle over a stated window is an output of the system, not a project.
- Everything runs on the entity's premises. No payload content is captured or hashed anywhere in the pipeline, which is what allows a Data Protection Officer to clear it under the DPDP Act by field-level review rather than a data-flow redesign.

4. Maturity, stated plainly

Maturity: the software accountability core is at TRL 5 — validated in a relevant environment — and now at the 5/6 boundary. We state it by component rather than as one number. The core described in the attached brief — the observer, the off-host collector, the reconciler and the evidence chain — has been validated against a real Linux kernel with an independently built external observer, under adversarial scenarios including a live attack on the observation path itself, with the raw output recorded. Since the previous revision it has also been run against an **unmodified third-party agent framework** rather than an agent harness of our own, and its coverage has been stated against an **external attack corpus we did not write** (Atomic Red Team / MITRE ATT&CK), in which 6 of 20 techniques are marked **not covered**. **We are still not claiming TRL 6, and we would rather tell the Department why than round the number up.** Two conditions remain. **First**, a non-synthetic agent under representative load: the framework on the other end is now real, but the work it does is not, and that is precisely what a pilot supplies. **Second**, independent corroboration — **now done on both axes**. Two independently built runtime observers found no execution absent from our signed evidence, and our identity binding cross-checks against **SPIFFE/SPIRE**, which agrees on a live workload and catches one re-pointed at unapproved code. These exercises found **four defects in our own code and none in the third-party systems**; the brief reports each with the test that now guards it. **That leaves exactly one condition between this and TRL 6: a real agent, doing real work, in a regulated entity — and it is the one only a pilot can supply, which is precisely what we are asking the Department to help make possible.**

The attached technical brief carries a list of eleven pre-production blockers, stated by us, unprompted, including an independent security assessment by a CERT-In empanelled auditor which we have not had. We would rather the Department see that list now than discover it later. We hold two Indian patent applications around the broader architecture.

5. What we would demonstrate, live

- The honest path: an authorised action observed executing, reconciled to VERIFIED_EXECUTION.
- An **interfered-with observer**: an attacker with CAP_BPF blinds a kernel sensor; the observer signs an integrity failure and the system answers CANNOT_PROVE with a reason, rather than a false accusation against an innocent workload.
- A connection to an **unregistered destination** refused before the act, against the institution's own signed registry of named systems.
- A **mis-parameterised tool call** caught against a gateway-countersigned receipt, where the finding does not rest on the agent's own account of what it asked for.
- **Offline verification performed by your side**, on your hardware, with keys you hold. To be exact about what that means: the verifier we ship is one implementation of a published, canonically encoded format, it opens no network connection and reads nothing from us at run time, and your side is free to write its own against the same specification. The trust rests on the format and on your keys, not on our binary being honest.

6. The pilot we would propose, if the evaluation warrants it

One regulated entity, a small number of Linux hosts running an AI agent that takes consequential actions. **Observer-only and advisory: nothing freezes a process, drops a packet, changes a firewall or sits in a transaction's critical path.** If the observer degrades, the entity's workload is unaffected and only our coverage claim shrinks. Five phases, each with a falsifiable exit gate; the fourth is adversarial validation on the entity's own hosts, and a pilot that skips it has not established honesty whatever the happy path shows.

Enclosed

Sniffer Dog / AIP: Technical Brief (14 pages) — architecture, independent authorities and key custody, what is observed and what is deliberately not, the verdict vocabulary, the security model, what has been demonstrated and what has not, the threat model, the proposed pilot with its exit gates, and the eleven pre-production blockers.
Further repository documents — including a requirement-by-requirement coverage matrix against the RBI, CERT-In and DPDP instruments, and an adversarial results ledger with one row per executed attack — are available on request.

Naga Sri Ganesh Kanumuri | Founder & CTO, VANIAN Technologies | Indian deep-tech, accountability infrastructure for autonomous AI